

Azure Compliance Implementation Checklist

Document:	sample_azure_compliance_document.txt
Frameworks:	ISO27018
Total Items:	4
Generated:	2025-11-26 13:05:01 UTC

Item #1: Implement Explicit Consent Management for PII Processing

Priority:

CRITICAL

Effort:

Complex

Description:

Establish a clear and documented process for obtaining, recording, and revoking consent for PII processing within the Azure environment. This ensures compliance with data privacy regulations and provides transparency to data subjects.

Gap Addressed: Lack of explicit details on consent management for PII processing in the cloud environment.

Azure Portal Navigation: Azure Portal > Azure Active Directory > App registrations > [Your App] > Authentication

Settings to Configure:

Setting Name:	Supported account types
Current Value:	Accounts in this organizational directory only
Required Value:	Accounts in any organizational directory (Any Azure AD directory - Multitenant) and personal Microsoft accounts
Location:	Azure Portal > Azure Active Directory > App registrations > [Your App] > Authentication > Supported account types

Step-by-Step Implementation Guide:

Step 1: Navigate to Azure Portal > Azure Active Directory

Click on 'Azure Active Directory' in the left navigation menu.
What to look for: You should see the Azure AD overview page.

Step 2: Go to App registrations > [Your App]

In the left menu, click 'App registrations' and select the application used for PII processing.
What to look for: You should see the application overview page.

Step 3: Go to Authentication

In the left menu, click 'Authentication'.
What to look for: You should see the Authentication settings page.

Step 4: Configure 'Supported account types'

Change the 'Supported account types' to 'Accounts in any organizational directory (Any Azure AD

directory - Multitenant) and personal Microsoft accounts (e.g. Skype, Xbox)'.

What to look for: The 'Supported account types' should be updated to the selected value.

Step 5: Implement a consent capture mechanism

Develop a custom consent capture mechanism using Azure Logic Apps or Azure Functions to record user consent in Azure Storage (e.g., Azure Table Storage or Azure Blob Storage). This mechanism should capture the date, time, and scope of consent.

What to look for: A record of user consent should be stored in Azure Storage.

Verification Steps:

- Step 1: Verify that the application registration is configured to allow multi-tenant accounts.
- Step 2: Test the consent capture mechanism by simulating a user granting consent. Verify that the consent record is stored correctly in Azure Storage.
- Step 3: Implement a mechanism to revoke consent and verify that the revocation is properly recorded and enforced.

Azure Services Required: Azure Active Directory, Azure Logic Apps, Azure Storage

Expected Outcome: Compliance with ISO 27018 requirements for obtaining and managing consent for PII processing.

Framework Reference: ISO/IEC 27018:2019 8.1.2

Additional Notes: Ensure the consent mechanism is user-friendly and provides clear information about the purpose of PII processing.

Item #2: Establish Data Subject Rights (DSR) Procedures

Priority:

CRITICAL

Effort:

Complex

Description:

Define and implement clear procedures for data subjects to exercise their rights (access, rectification, erasure, restriction of processing, data portability, and objection) within the Azure cloud environment. This includes providing a user-friendly interface and timely response mechanisms.

Gap Addressed: Insufficient information on how data subjects can exercise their rights (access, rectification, erasure, etc.) within the Azure cloud.

Azure Portal Navigation: N/A - Requires custom implementation

Settings to Configure:

Setting Name:	DSR Request Portal
Current Value:	None
Required Value:	Implemented and Accessible
Location:	N/A - Custom Implementation

Step-by-Step Implementation Guide:

Step 1: Develop a DSR Request Portal

Create a web-based portal or form where data subjects can submit DSR requests. This portal should be accessible through a clearly defined URL.

What to look for: A user-friendly interface for submitting DSR requests.

Step 2: Implement DSR Request Processing Logic

Use Azure Logic Apps or Azure Functions to automate the processing of DSR requests. This includes identifying the data subject, locating their PII within Azure Storage, Azure Data Lake Storage, and other relevant services, and performing the requested action (access, rectification, erasure, etc.).

What to look for: Automated workflows for processing DSR requests.

Step 3: Implement Data Access Controls

Ensure that only authorized personnel have access to PII when processing DSR requests. Use Azure Role-Based Access Control (RBAC) to restrict access to sensitive data.

What to look for: Appropriate access controls in place to protect PII.

Step 4: Document DSR Procedures

Create detailed documentation outlining the DSR request process, including roles and responsibilities, timelines, and escalation procedures.

What to look for: Comprehensive documentation of DSR procedures.

Verification Steps:

- Step 1: Submit a test DSR request through the portal.
- Step 2: Verify that the request is processed correctly and that the requested action is performed (e.g., access to data is granted, data is rectified, or data is erased).
- Step 3: Monitor the processing time for DSR requests to ensure compliance with regulatory requirements.
- Step 4: Review access logs to ensure that only authorized personnel accessed PII during the DSR request process.

Azure Services Required: Azure Active Directory, Azure Logic Apps, Azure Storage, Azure Data Lake Storage

Expected Outcome: Compliance with ISO 27018 requirements for enabling data subjects to exercise their rights.

Framework Reference: ISO/IEC 27018:2019 8.2.1

Additional Notes: Provide clear communication to data subjects throughout the DSR request process.

Item #3: Enhance Transparency Regarding Cryptography Usage

Priority:

HIGH

Effort:

Moderate

Description:

Provide detailed information to customers regarding the specific circumstances in which cryptography is used to protect PII within the Azure environment. This includes specifying the encryption algorithms used, key management practices, and any capabilities offered to customers for applying their own cryptographic protection.

Gap Addressed: Limited transparency regarding the specific circumstances in which cryptography is used to protect PII and the capabilities offered to customers for applying their own cryptographic protection.

Azure Portal Navigation: N/A - Documentation and Communication

Settings to Configure:

Setting Name:	Cryptography Documentation
Current Value:	Limited
Required Value:	Comprehensive
Location:	N/A - Documentation

Step-by-Step Implementation Guide:

Step 1: Document Cryptography Usage

Create a comprehensive document outlining the specific circumstances in which cryptography is used to protect PII within Azure. This document should include details on encryption algorithms, key management practices, and customer-facing cryptographic capabilities.

What to look for: A detailed document covering all aspects of cryptography usage for PII protection.

Step 2: Publish Cryptography Documentation

Make the cryptography documentation readily available to customers through a secure and easily accessible channel (e.g., a dedicated section on the company website or a secure document repository).

What to look for: Easy access to the cryptography documentation for customers.

Step 3: Provide Guidance on Customer-Managed Encryption

Offer clear guidance and support to customers who wish to apply their own cryptographic protection to PII stored in Azure. This includes providing information on Azure Key Vault, Azure Disk Encryption, and other relevant services.

What to look for: Clear guidance and support for customer-managed encryption.

Verification Steps:

- Step 1: Review the cryptography documentation to ensure it is comprehensive and accurate.
- Step 2: Verify that the documentation is easily accessible to customers.
- Step 3: Test the customer-managed encryption guidance to ensure it is clear and effective.

Azure Services Required: Azure Key Vault, Azure Storage, Azure SQL Database, Azure Disk Encryption

Expected Outcome: Compliance with ISO 27018 requirements for providing transparency regarding cryptography usage.

Framework Reference: ISO/IEC 27018:2019 9.1.1

Additional Notes: Regularly update the cryptography documentation to reflect changes in Azure services and security practices.

Item #4: Define PII Protection Responsibilities in Contractual Agreements

Priority:

HIGH

Effort:

Moderate

Description:

Clearly specify the PII protection responsibilities of all organizations involved in providing or using the cloud services, including the cloud service provider, its subcontractors, and the cloud service customer. This should be documented in contractual agreements.

Gap Addressed: The document does not explicitly address the contractual agreements needed to specify PII protection responsibilities between the cloud service provider, its subcontractors, and the cloud service customer, as highlighted in ISO/IEC 27018:2019.

Azure Portal Navigation: N/A - Contractual Agreements

Settings to Configure:

Setting Name:	PII Protection Clauses in Contracts
Current Value:	Insufficient
Required Value:	Comprehensive
Location:	Contractual Agreements

Step-by-Step Implementation Guide:

Step 1: Review Existing Contracts

Review all existing contracts with cloud service customers and subcontractors to identify any gaps in PII protection responsibilities.

What to look for: Gaps in PII protection responsibilities.

Step 2: Update Contract Templates

Update contract templates to include comprehensive clauses specifying the PII protection responsibilities of all parties involved. These clauses should address data security, data privacy, breach notification, and compliance with relevant regulations.

What to look for: Comprehensive PII protection clauses in contract templates.

Step 3: Negotiate Contract Amendments

Negotiate contract amendments with existing customers and subcontractors to incorporate the updated PII protection clauses.

What to look for: Signed contract amendments incorporating the updated PII protection clauses.

Verification Steps:

- Step 1: Review the updated contract templates to ensure they include comprehensive PII protection clauses.
- Step 2: Verify that all new contracts include the updated PII protection clauses.
- Step 3: Track the progress of contract amendments with existing customers and subcontractors.

Azure Services Required: N/A - Contractual Agreements

Expected Outcome: Compliance with ISO 27018 requirements for defining PII protection responsibilities in contractual agreements.

Framework Reference: ISO/IEC 27018:2019 5.1.1

Additional Notes: Consult with legal counsel to ensure that the PII protection clauses are legally sound and enforceable.